



RISK MANAGEMENT DEPARTMENT

Enterprise Risk Management Framework

↻NSSF/ERM/PD/03↻

ISSUE NO. 02

ISSUED BY: Management Representative

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

DOCUMENT APPROVAL PAGE

NATIONAL SOCIAL SECURITY FUND		
DEPARTMENT: Risk Management	Reference No.	
	Revision No. 01	Date: 16/05/2025
	Prepared by:	Mahmoud Sebit Maureen Emase Gideon Ngome
TITLE: ERM	Reviewed by:	Date: 16/05/2025
	Chris Lokipi MANAGER, RISK MANAGEMENT	
	Approved by:	Date:
	Mr. David Koross, MBS MANAGING TRUSTEE/CEO	

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

REVISION HISTORY OF DOCUMENTED INFORMATION

DOCUMENT TITLE: **Enterprise Risk Management Framework**

Rev. No.	DCR Ref.	Date	Chapter/ Clause/ Par. No	Details of changes Addition – Underline/highlight Deletion – Strikethrough

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Table of contents

	<u>Page</u>
Acronyms & Abbreviations	5
1.0 Introduction	
1.1. Objectives of the ERM Framework	6
1.2. Basis of preparation	7
1.3. ERM Definition	7
1.4. ERM Terminology	8
2.0 ERM Policy Statement	9
2.1 Guiding principles	9
2.2 Risk awareness culture	9
3.0 NSSF Risk Management Systems	11
3.1 Objective setting	11
3.2 Linking risk with the Fund strategic & business plans	11
3.3 NSSF ERM process	11
3.4 Risk Assessment	12
3.4.1 Risk Identification	12
3.4.2 Risk Analysis	13
3.5 Risk Evaluation	
3.6 Risk Response	14
3.7 Risk Monitoring	15
3.8 Risk Reporting	15
3.9 Risk Reporting Framework	15
4.0 Roles & Responsibilities	17
5.0 Compliance Policy	20
5.1 Responsibilities for Compliance	20
5.2 Compliance Reporting	20
6.0 Implementation of the ERM	21
6.1 Revision of the ERM Framework	21
ANNEXES	
NSSF Risk Assessment Matrix	22
TOR for the Audit & Risk Committee in relation to ERM	23
Risk Champions- Roles & Responsibilities	24

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Definitions

Enterprise Risk Management (ERM)

ERM is “a process, effected by an entity's Board of Trustees, management and other personnel, applied in strategy setting and across the enterprise, designed to identify potential events that may affect the entity, and manage risk to be within its risk appetite, to provide reasonable assurance regarding the achievement of entity objectives” Committee of Sponsoring Organizations of the Treadway Commission. (COSO)

NSSF/Fund

Means National Social Security Fund. The two terms are used interchangeably in the policy as appropriate.

Business Unit

Refers to a Department, Region, Branch, Section or Unit of NSSF.

Event

An occurrence or incident, from external or internal sources, that affects the achievement of the Funds objectives. Events can have negative consequence, positive consequence, or both. Events with negative consequence represent threats. Events with positive consequence represent opportunities.

Risk

The Fund defines “Risk” as: “The effect of uncertainty on objectives” Risk relates to the occurrence of one or more future events that can have an impact on the Fund's objectives. Objectives can be under achieved or overachieved due to risk.

Impact

The effect a risk will have on the Fund’s finances, information, operations and/or reputation if it occurs.

Likelihood

A chance of an event occurring

Vulnerability

The weakness of an asset or control that can be exploited by one or more threats

Inherent risk

Risks in the absence of any mitigating actions taken to reduce either the risk’s likelihood/vulnerability of occurrence or impact.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Controls

A measure that maintains and/or modifies risk.

Residual risk

Risk remaining after risk treatment. The remaining levels of risk after risk mitigation measures have been taken.

Risk Assessment

Process of identifying, analyzing and evaluating risks.

Risk register

A document of risk management systems, on which all significant risk factors for the Fund are identified, ranked and assigned.

Risk appetite

The amount of risk, on a broad level, an organization is willing to accept in pursuit of stakeholder value. This is based on informed decision on the impact & vulnerability of a particular risk.

Risk tolerance

The specific maximum risk that the Fund is willing to take regarding each relevant risk.

Risk treatment

The strategies put in place by the Fund to modify, reduce or eliminate the risk

Annex A

Control objectives and controls listed in table A1 of the ISO/IEC 27001:2022

Statement of Applicability It is a summary of the Funds position on each of the 93 information security controls outlined in Annex A.

Risk Owner

Person or entity with the accountability and authority to manage a risk. Risk owners are staff with the primarily responsibility for particular risks and controls.

Risk Champion

An officer who supports and defends risk management cause. Therefore, a champion of risk management promotes its benefits, educate the business unit's management and staff in the actions they need to take to implement it and will encourage them and support them in taking those actions.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Management

Refers to officers of the Fund in charge of a department, region, division, station, project, section or unit within the Fund.

Process

Refers to a set of interrelated or interacting activities which transform inputs into outputs in order to achieve desired results.

Risk culture

The set of shared attitudes, values and practices that characterize how the Authority considers risks in its day-to-day activities.

Risk Drivers

These are the causes of risk events.

Risk indicator

These are measurements or parameters used by management to show how risky an event or activity is. They warn of the most obvious areas where problems may arise, thus the term Key Risk Indicators (KRI).

Risk profile

A documented and prioritized assessment of the range of specific risks faced by the Fund.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Acronyms and Abbreviations

ARC	Audit & Risk Committee
BOT	Board of Trustee's
BM	Branch Managers
COSO	Committee of Sponsoring Organizations of the Treadway Commission
ERM	Enterprise Risk Management
ERMF	Enterprise Risk Management Framework
HOD's	Heads of Departments
ISO	International Organization for Standardization
MT	Managing Trustee
NT	National Treasury
NSSF/ the "Fund"	National Social Security Fund
RM	Regional Managers
Senior Management	The Managing Trustee & General Managers
SOA	Statement of Applicability
DISRUPTION	Incident, whether anticipated or unanticipated, that causes unplanned, negative deviation from the expected delivery of products and services according to the Fund's objectives.

REFERENCES

ISO 9001:2015	-	Quality Management Systems
ISO 27001:2022	-	Information Security, Cyber Security and Privacy
Protection		Management Systems
ISO 30401:2018	-	Knowledge Management Systems
ISO 9004:2018	-	Quality Management-Quality of an Organization
ISO 22301:2019	-	Business Continuity Management System
ISO 31000 Risk Management	-	Principles and Guidelines.
The COSO ERM	-	Integrated framework.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

1.0 INTRODUCTION

The core mandate of NSSF is to provide basic social security benefits to members upon retirement.

The Fund recognizes that risk is inherent to its operations and that managing risk effectively is critical to the immediate and future success or the very existence of the Fund.

This policy recognizes that risks are caused by people, systems and external events. These causes of risks trigger risk events which may include fraud (internal or external), workplace health and safety, environmental, business disruption, system failure, or damage to assets. The effects of such events have the potential to affect positively or negatively on the achievement of objectives.

Risks have generally increased in today business environment due to a combination of reasons:

- 1.1 Financial liberalization has opened the door to new and sometimes unfamiliar business lines and risk
- 1.2 The operating environment has become more volatile and unpredictable as a result of macroeconomic and regulatory policy changes
- 1.3 Products continue to increase in complexity as competition intensifies
- 1.4 Trading margin compression has intensified, coercing businesses to take greater risk in order to protect income,
- 1.5 Customers are actively exercising their rights and choices, and have become very risk sensitive
- 1.6 Fraud/ crime is becoming increasingly sophisticated.
- 1.7 The new technology acquired has altered the risk equation, mitigating some risks such as human error, while adding new ones.

2.0 PURPOSE

The aim of the Enterprise-Wide Risk Management is to give assurance that management always knows what is at risk and that the Fund does not suffer loss from risks that were either ignored or misunderstood. Active management of these risks is an essential part of the Fund's operations and a key determinant of its ability to maintain a growing capital and earnings base.

It is therefore imperative that all personnel have an in-depth understanding of the various risks that have bearing on the operations of NSSF and the types of risks that are associated with each line of the business, including support functions.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

3.0 OBJECTIVES OF ERM FRAMEWORK

3.1 The objecting of this framework is to bring a structured approach to risk management in the entire Fund. The ERM framework is a tool that is forward looking, anticipating any potential impediments/risks that can impact on the achievement of strategic objectives and proposing appropriate risks mitigation measures. This document is the overriding policy for overall risk management within the Fund. It is designed to ensure that: -

- 3.1.1 The Board of Trustees and management have an active, structured, and commonly shared knowledge of risks and priorities.
- 3.1.2 There is a management structure that adequately identifies, measures, monitors and controls the risks involved in various products, operations, and lines of business.
- 3.1.3 Management takes the right decisions in uncertain environment and also establish pre-emptive strategies to enhance service delivery.
- 3.1.4 Management understands the nature of risks and ensure that necessary steps are taken to mitigate the potential negative consequences.
- 3.1.5 Management evaluates, prioritizes and addresses the critical risks and channel resources to these risks, ultimately improving the utilization of resources and quality of services rendered.
- 3.1.6 Roles and responsibilities are clearly defined for each stakeholder in the ERM spectrum.
- 3.1.7 Risk reporting is clearly defined and communicated.
- 3.1.8 Resources are assigned to management of risks in a manner to optimise the achievement of the Fund's objectives.
- 3.1.9 To ensure that all the current and future risk exposures of the Fund are identified, assessed, quantified, appropriately mitigated and managed.
- 3.1.10 To enable compliance with appropriate regulations, wherever applicable through the adoption of best practices.
- 3.1.11 To assure stability and resilience in contribution collection.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

4.0 BASIS OF PREPARATION OF THE ERM

- 4.1 This framework has been developed to comply with the Kenyan Government (Treasury Circular 3/2009) directive on the implementation of an Institutional Risk Management Framework for Kenya's Public was enacted into law through the Public Finance Management Act and its attendant regulations. The Mwongozo Code of Governance requires the Fund to have adequate systems and processes of accountability, risk management and control.
- 4.2 This policy links to other policies e.g. Information Security Policy, Business Continuity Policy, Anti-fraud and Anti-Corruption Policy, Security Management Policy and Compliance Risk Management Policy.

5.0 ERM POLICY GUIDING PRINCIPLES

- 5.1 The Fund is committed to embedding risk management principles and practices into:
 - 5.1.1 Strategic and Operational plans
 - 5.1.2 Decision making process
 - 5.1.3 Business and financial processes
 - 5.1.4 All levels of the Fund; i.e. Division, Departments, Regions, Branches, and Huduma Centres
 - 5.1.5 On major projects undertaken
 - 5.1.6 On major transactions entered into with third parties.
- 5.2 Risk management is based on the proposition that it must produce value to the Fund- the benefit of reducing risk must be greater than the cost of its management.
- 5.3 Risk Management is everybody's responsibility, from the Board of Trustees to individual employees.
- 5.4 Each business unit is expected to undertake risk assessments on no less than an annual basis and quarterly as may be determined by the Audit & Risk Committee of the Board of Trustees.
- 5.5 Enterprise Risk Management will be integrated with major business processes such as strategic planning, business planning and operational management to ensure consistent consideration of risks in all decision-making.
- 5.6 The Fund's guidelines, policies, procedures and processes will be consistent with this Framework.
- 5.7 Risk Management is mandatory and not optional.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

6.0 Risk Awareness culture

- 6.1 Risk management shall be integrated into the culture of the Fund. This will include mandate, leadership and commitment from the Board of Trustees.
- 6.2 Risk culture is a term describing the values, beliefs, knowledge and understanding about risk shared by a group of people with a common purpose, in particular the employees of an organisation or of teams or groups within an organisation (Institute of Risk Management-IRM).
- 6.3 Achieving a good risk awareness culture is ensured by establishing an appropriate risk architecture, strategy and protocols.

6.4 Guiding principles

- 6.4.1 A distinct and consistent tone from the BOT and senior management in respect of risk taking and avoidance.
- 6.4.2 A commitment to ethical principles, reflected in a concern with the ethical profile of individuals and the application of ethics and the consideration of wider stakeholder positions in decision making.
- 6.4.3 A common acceptance through the organisation of the importance of continuous management of risk, including clear accountability for and ownership of specific risks and risk areas.
- 6.4.4 Transparent and timely risk information flowing up and down the organisation with adverse news rapidly communicated without fear of blame.
- 6.4.5 Encouragement of risk event reporting and whistle blowing, actively seeking to learn from mistakes and near misses.
- 6.4.6 No process or activity too large or too complex or too obscure for the risks to be readily understood
- 6.4.7 Appropriate risk taking behaviours are rewarded and encouraged and inappropriate behaviours are challenged and sanctioned
- 6.4.8 Risk management skills and knowledge valued, encouraged and developed, with a properly resourced risk management function and widespread membership and support for professional bodies. Professional qualifications as well as technical training supported.
- 6.4.9 Sufficient diversity of perspectives, values and beliefs to ensure that the status quo is consistently and rigorously challenged.
- 6.4.10 Risk management shall be embedded in the Fund's Performance Management Systems.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

7.0 NSSF RISK MANAGEMENT SYSTEMS

7.1 Risk Management Scope

The Fund recognizes the following major categories of risk

Risk Category	Description
Governance Risks	Risks related to structure, accountability, transparency, policies, procedures and authorities in which the key directions and decisions of the organization are overseen: (i) Board of Trustees independence & oversight (ii) Organisational culture & ethics (iii) Corporate Social responsibility (iv) Delegation of Authority
Strategy Risks	Risks associated with the Fund's inability to formulate and/or execute a successful business Strategy. i.e., innovation, brand promotion, seizing market opportunities, new products, stakeholder's needs, budgeting/allocation of resources, succession planning, obsolescing of existing product or services.
Operational Risks	Risks resulting from instances of inadequate or failed internal processes, people and systems or from external events. Risk of loss arising from inadequate IT systems, internal control lapses, fraud, catastrophes or other operational problems which may result in unexpected losses.
Financial Risks	Risks related to poor financial management within the organisation leading to inadequate returns & cash flows to meet financial obligations and accurately account for financial transactions such as; Accounting for contributions, processing of benefits payments, liquidity management, poor investment decisions, property management losses, etc.
Compliance Risks	Risks related to non-compliance with applicable laws, regulations (i.e. RBA, NSSF Act, Treasury Circulars, etc) and relevant internal & external policies. This could also affect the Fund's reputation.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Information Security Risks	These are risks that are associated with the loss of preservation of Confidentiality Integrity and Availability of information. In relation to the requirement of the Information Security Management System Standard, ISO/IEC 27001:2013, a detailed process has been defined in the Information Security Risk Assessment and Treatment Process (Annex 12.4) .
Business Continuity Risks	These are risks that affect continuity of critical/prioritized activities in the business processes.
Project risks	Project risk is an uncertain event or condition that, if it occurs, has an effect on at least one project objective
Fraud Risks	These are risks with the potential for intentional act of deception committed to secure an unfair or unlawful gain which can result in financial loss, reputational damages and regulatory penalties
Health & Safety	These are risks with the potential for harm to employees, contractors, visitors or the public as a result of unsafe working conditions, hazardous activities or noncompliance with OSHA regulations.
Environmental, Social & Governance (ESG)	These are risks arising from environmental, social or governance issues that can negatively affect an organizational performance, stake holders trust, regulatory compliance and ability to operate sustainably e.g. climate change, pollution, biodiversity loss

7.2 Linking risk with the Fund's strategic & business plans

- 7.2.1 There shall be a clear and meaningful reference to the management of risks within the Fund's strategic and business plans. Board of Trustees & Senior management shall ensure that the management of risk is considered as part of the strategic objectives and become an integral part of the Fund's day to day operations.
- 7.2.2 To ensure that the above policy is implemented and that the significance of managing risk is cascaded throughout all areas of the Fund's operations, the following shall be implemented.
- 7.2.3 Risk management shall be considered as part of decision making process and embedded within work plans and budgets;

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

7.2.4 Risk Management framework shall be communicated to all employees in the Fund.

7.2.5 Guidance and training shall be given to Fund employees in order to ensure that they are able to properly understand and manage risks falling within their area of responsibility and accountability.

7.2.6 Risk management shall be embedded in the performance management system of the Fund.

7.3 **NSSF's Risk Management Process**

Risk management process in the Fund will be done in accordance with the ISO 31000: 2018: Risk Management Principles and Guidelines.

The Fund will adopt a continuous process with the following key steps:

7.3.1 Establish the Context

7.3.1.(i) Risk Assessment

7.3.1.(i)(a) Risk identification

7.3.1.(i)(b) Risk Analysis

7.3.1.(i)(c) Evaluation

7.3.2 Risk Response

7.3.3 Risk Monitoring and Measurement

7.3.4 Risk Reporting

7.3.5 Improvement actions

7.4 **Establish the Context**

Defining the strategic, organisational and risk management context covering corporate objectives, criteria and key elements, issues and stakeholders, to establish the role of the Fund.

7.5 **Risk Assessment**

7.5.1 Risk assessment shall be carried out at all levels of the Fund at least annually and as part of major decision making process.

7.5.2 Risk Assessment involves the process of risk identification, risk analysis and evaluation.

7.6 **Risk Identification**

7.6.1 Risk identification is the process of determining risks that could potentially prevent the achievement of the objectives of the Fund.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

7.6.2 An event is an occurrence that could affect strategy implementation or achievement of objectives. Risk is the possibility that an event will occur and adversely affect the achievement of objectives. Events with negative impact represent **risks** while events with positive impact represent **opportunities**. Risks require immediate management actions to reduce them while opportunities can be channeled back into the strategy and objective-setting processes.

7.6.3 The Fund will classify the identified risks into the categories indicated in the table below:

7.7 Risk Analysis

7.7.1 The identified risks will be measured and ranked using the NSSF Risk Assessment Matrix. The identified risks will be assessed and measured to determine their level (weight) and ranked so as to assign priorities using the NSSF Risk Assessment Matrix (**Annex 12.1**). The analysis shall be done based on two parameters.

7.7.1.(i) The potential impact if the risk occurs (financial, stakeholders, reputation, business process & systems, etc)

7.7.1.(ii) The likelihood: The likelihood of occurrence taking into consideration the existing controls that have been put in place.

7.8 Risk Evaluation

7.8.1 Risks will be ranked in terms of High (H), medium/ Moderate (M) and Low (L) as defined by the parameters in the Matrix. The colour code Table 3 below will be used. High risks must be reported to Senior Management and require detailed treatment plans to reduce the risk to Low or Medium.

7.8.2 Apply the risk acceptance criteria on the risk values to determine the risk significance and prioritize. All high risks are 1st priority, all medium risks are prioritized gradually in relation to the score.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Table 3

Risk Ranking	Colour	Acceptance Criteria	Recommendation Action
High (H)	15 - 25	Unacceptable	Controls must be implemented with immediate detailed action plan required at senior management and Board Level
Medium /Moderate (M)	5 - 12	Tolerable	Controls must be implemented needs management attention
Low (L)	1 - 4	Acceptable	Managed by normal activities/Only monitoring

7.9 Risk Response

- 7.9.1 The Fund's Management shall ensure that appropriate risk responses will be instituted to mitigate the identified risks to an acceptable level.
- 7.9.2 Risk response is the activity of selecting and implementing appropriate control measures to modify the risk. Risk response includes as its major element, risk control (or mitigation), but extends further to, risk avoidance, risk transfer, risk acceptance & exploiting the risk.
- 7.9.3 In responding to risks management, the Fund will apply the following key risk treatment options: -

Table 4

Risk Treatment Options	Description
Treat Reduce/Mitigate	Reduce the impact of the risk or vulnerability or both so that the exposure is reduced. Examples include: (i) Additional internal controls such as segregation of duties, assignment of responsibility and accountability (ii) Policies & procedures (iii) budgets and forecasts (iv) Implementing BCP programmes
Terminate/Avoidance	This is where the Fund decides to avoid the risk in its entirety. Some projects or actions could have too much associated risks and a deliberate decision is made not to proceed or the scope and scale are changed.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Transfer/ Share	This is where the risk or a portion of it is transferred to a third party, i.e. insurance
Tolerate/Accept	Where an informed decision is made to accept the risk. No resources are allocated to the risks.
Exploit risk	Steps taken to leverage on opportunities. This could include revising the strategy and plans to take advantage of the opportunities.

7.10 Risk Monitoring

7.10.1 The Fund shall continuously monitor the risk throughout the Fund. Continuous risk monitoring will give assurance that:

- 7.10.1.(i) Risks are managed properly
- 7.10.1.(ii) Risk response plans remain relevant and cost effective
- 7.10.1.(iii) New risks exposures are effectively mitigated
- 7.10.1.(iv) Resources are efficiently allocated/ re-allocated based on the risk profiles.

7.10.2 Risks shall be monitored through regular communications, periodic tests of controls for design effectiveness and relevance and through internal audit reviews.

7.11 Risk Reporting

7.11.1 Policy Statement:

7.11.1.(i) Risk information shall be communicated both upwards & downward throughout the Fund to the relevant stakeholders.

- 7.11.1.(i)(a) Reporting is a key element of the risk management process. The Board of Trustees and Senior Management must be kept abreast of key risks and the actions resulting from risk management activities.
- 7.11.1.(i)(b) While risk management is the responsibility of everyone in the Fund, different categories in the Fund have

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

different reporting requirements and responsibilities at every level in the Fund i.e. Board of Trustees; Senior Management; Operational Staff.

7.11.2 Risk Reporting Framework

7.11.2.(i) A number of reports will be generated. The table below summarises the reports, frequency, information contained and the use of the report:

Table 5

Risk Report	Frequency	Information	Use of the Report
Risk Advisory	Adhoc	Template capturing the risk as they are identified either by Internal Audit, Risk Department staff, or business unit Risk Champions.	Used by the management to track risks and respond to the identified risks. Risk owners to comment on the risk response actions taken.
Risk Management Report	Adhoc	All risk management reports done as per the work plan.	Key risks and mitigations discussed with risk owners.
Board Risk Management Report	Quarterly	Summarises of key strategic, operational, compliance and emerging risks noted during the quarter and the mitigating actions taken.	Discussed with Senior Management and Risk Management Unit. Discussed at the Audit Committee meetings and BOT
Corporate Risk Register Update	Annually	Fund-wide risks	Used by Senior Management to

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

		identification and the overall Risk Register updated.	give an overall risk profile of the Fund.
--	--	---	---

8.0 RISK APPETITE AND TOLERANCE

Risk appetite determines the amount of risk that shall be considered acceptable to take, in pursuit of corporate objectives. The risk appetite of the Fund will be set by the Board of Trustees from time to time and will be determined for each major risk type and documented in a separate risk appetite / tolerance statement.

The setting of a risk appetite recognises the fact that the Trustees of NSSF are willing and want a certain level of risk since it opens opportunities to meet and / or exceed certain objectives. This implies that a risk appetite is only appropriate for risks that have an upside (potential positive consequence). These risks are; Credit Risk, Market Risk and Strategic Risk.

Certain risks have no recognised upside and as such would ideally be eliminated. However, elimination is usually not possible due to cost and benefits considerations. For these risks, the Fund therefore has a tolerance.

Risk tolerance applies to, Operational Risk, Liquidity Risk, Strategic Risk and Market Risk. For these risks, mitigation strategies will be considered to the point that the cost of additional mitigation is expected to exceed the benefits of increased minimization.

For risks involving any human deliberate acts such as non-compliance to regulatory or internal policies, corruption, fraud, drug abuse, sexual harassment, reputation damage, breakdown to information system, information integrity, risk of injury to staff and or customer, the appetite is zero and additional measures should be sought, as far as possible, to eliminate these types of risks.

For the rating of likelihood and consequence used in the Risk and Control Self-Assessment and in assessing indirect consequences when an incident is recorded, the Fund uses a rating of 1 to 5. The meaning of each scale of 1 to 5 is explained in the Risk Appetite Statement of the Fund.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

For reporting purposes, self-assessed risks and key risk indicators will be analysed using a five-point scale and classified into high (red), medium (amber) and low (green), in accordance with the risk appetite statement. For risks that are high (red) and medium (amber), potential improvements must be implemented. Where no further improvements are possible or economic, the risk must either be avoided or formally accepted by Management.

Risk identified shall be analysed on the basis of likelihood of occurrence and the consequences if they occur. The two dimensions will use a five-point scale. The risks will be ranked using the product of the likelihood score (L) and the consequence score (C) to determine its ranking score (R) and classified using a three level scale with corresponding colour schemes as follows: -

RANK	COLOUR SCHEME
Low	Green
Medium	Amber
High	Red

9.0 RISK MANAGEMENT TOOLS

Risk & Control Self-Assessment

Tool used to conduct adequate risk assessment consistent with the Risk Identification, Analysis, Evaluation and Treatment of risks as per ISO 31000 Risk Management Process.

Key Risk Indicators

Proxies to monitors key risks identified across the organisation. It is consistent with Monitoring and Review stage of ISO 31000 Risk Management Process.

Incident Management

Central systems to record and manage risk incidents when they occur for analysis of weaknesses and also as a basis of data for future analysis. It is consistent with Monitoring and Review stage of ISO 31000 Risk management Process.

Mitigation Action Tracking

Central systems to record and manage all actions within the organisation. It is consistent with Monitoring & Review and Communicate & Consult stage of ISO 31000 Risk Management Process.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Compliance to internal and external requirements

Proactive system to monitor Internal Compliance (compliance with internal controls and policies) and External Compliance (compliance with external rules and regulations). It is consistent with Monitoring & Review and Communicate & Consult stage of ISO 31000 Risk Management Process.

10.0 STAFF TRAINING

Relevant staff must receive ongoing training in relation to the implementation and maintenance of the risk management framework. This training consists of, but is not restricted to training of:

- Board and Senior Management on the overall concepts and framework
- Risk Champions in the detailed operation of the framework and related systems
- Employees in overall awareness and responsibilities

11.0 ERM ROLES AND RESPONSIBILITIES

- 11.1.1 The Board of Trustees is ultimately responsible for risk management in the Fund. The BOT has delegated the oversight role of risk management to the Audit & Risk Committee. Risk Management is the responsibility of all staff within their limits of accountability and responsibility in their respective areas.
- 11.1.2 The Heads of Departments, RM's, BM's & OIC's shall be accountable for the risk management in their respective areas of functional responsibility.
- 11.1.3 The Fund shall nominate Risk Champions at each business unit level. The champions will be trained in risk management and shall play a key role in facilitating and coordinating risk management activities within their Departments/Regions/Branches & Sub-Branchees.

- 11.2 For ERM to be successful, parties in this framework must play their roles effectively. The roles should be embedded within the existing organisation structures and reported through the existing communication channels.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Table 6

Parties	Roles & responsibilities
The Board of Trustees	(i) The BOT is responsible for oversight and shall, through the Board Audit Committee, ensure the maintenance of this framework. (ii) Appraised on a timely basis of the Fund's major risks through the Audit & Risk Committee or the Managing Trustee. (iii) Review, concur with and approve the Fund's risk management plans and major risk response strategies. (iv) Obtain assurance from the Managing Trustee that the framework for the effective management of risk is in place. (v) The Board shall have the oversight responsibility to review adequacy and effectiveness of the overall arrangements put in place by management and annual Risk Register to ensure adequate controls and measures have been developed to mitigate risks. (vi) The BOT shall provide appropriate resources for risk management.
Audit & Risk Committee (ARC)	The Board of Trustees has delegated the oversight role over risk management to the Audit & Risk Committee. The role and responsibility of the Audit & Risk Committee regarding risk management is as specified in Annex 12.2
Managing Trustee (MT)	The MT has the ultimate accountability for managing the Fund's risks. (i) The MT shall ensure that specific risk management accountabilities are established, properly documented and maintained by the Fund. (ii) The MT is responsible for ensuring that this framework is active in all departments/regions/branches within NSSF. (iii) The MT shall be responsible for the implementation of this framework and shall direct senior management under the guidance of the Manager, Risk to collate and assess risks from all departments. (iv) Establish appropriate whistle blowing programme in line with the Fund's policies. (v) Receive and approve reports on risk management issues.

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

Senior Management Team	The Senior Management shall be responsible for delivery and maintenance of risk management systems within NSSF. Their role shall be: (i) Receiving and discussing quarterly risk management reports with the RM Department & Risk owners Assessing progress made against agreed action plans. (ii) Examine and analyse the Risk Register before it is presented to the Board Audit & Risk Committee and ask critical questions of each risk owner. (iii) They shall also follow-up on action plans recommended by the Board and approve risk mitigating actions proposed by Risk Owners. (iv) The committee shall provide support of risk management activities in the Fund. (v) Arranging/providing risk management training as appropriate.
Manager, Risk Management	The Risk Management Department shall coordinate risk management activities throughout the Fund. It shall act as an organ which reviews the effectiveness of the Fund's risk management efforts as well as emerging issues/concerns. The Risk Manager shall: (i) provide support to senior management on reporting and consolidation of risks; (ii) select, develop and maintain systems required to support the risk assessment process for the various departments; (iii) Coordinate risk reporting throughout the Fund by consolidating quarterly & annual risk management reports to Senior Management & the Audit & Risk Committee. (iv) Monitor and report upon trends in the Fund's risk profiles over time. Further, the Risk Manager shall: (i) be the custodian of appropriate risk methodologies and templates; (ii) monitor progress against action plans designed to manage operational risks; and (iii) Identify training needs on risk management across the

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

	Fund.
HOD's/ RM's/ BM's/OIC's	(i) Each will ensure that a Risk Register is established and properly maintained by the Department/Regions/branches. (ii) They will also ensure that risk responses are implemented to address risks that have been identified and classified as major.
Risk Champions	They shall be the main point of contact between their respective departments/regions/branches and the Risk Management Department. The detailed roles and responsibilities are defined in Annex 12.3
Individual employees	Individual employees are personally responsible for managing risks in their functional areas within the scope of their authority, responsibility and accountability.
Risk Owners	These are staff with the primarily responsibility for particular risks and controls. Each Risk Owner must ensure that the risks they are responsible for is adequately mitigated, monitored & timely reported to the RM Department. Effective risk management will form part of performance contracts for all Risk Owners.
Internal Audit Function	The Internal Audit Department shall independently appraise the Fund's operations, assess the effectiveness of internal controls and help ensure conformance with the policies & procedures. They shall review the effectiveness of the risk management at the overall organisation level and at the individual business units during their audits.
External Auditors	In the course of the financial audits, they could provide information useful to management in carrying out its risk management-related responsibilities.
External Contractors	External contractual parties who act as agents for NSSF, such as outsourced service providers and partnering institutions, have an obligation to fulfil their contractual responsibilities including the safeguarding of NSSF assets, where relevant. Staff members responsible for their supervision must ensure this is done

DEPARTMENT	RISK MANAGEMENT DEPARTMENT	
TITLE OF DOCUMENT	ENTERPRISE MANAGEMENT FRAMEWORK	
DOCUMENT NUMBER	SF/IAR/PD/03	
ISSUE NUMBER	02	

13.0 ANNEXES

- 13.1 - TOR for the Audit & Risk Committee in relation to ERM
- 13.2 - Risk Management Champions - Roles and Responsibilities
- 12.4 - Information Security Risk Assessment and Treatment Process

IMS 000

ANNEX 12.2: TOR FOR THE AUDIT & RISK COMMITTEE IN RELATION TO ERM

The Board of Trustees has delegated its risks management responsibilities to the Audit & Risk Committee. The main purpose of the Committee is to assist the BOT in discharging its duties relating to identification of key risk areas, measurement and control of risk, and formulating risk management policies. The Committee is responsible for the quality, integrity and reliability of the Fund's risk management program, on behalf of the Board of Trustees. The duties of the Committee are as follows:

- 1) Set out the nature, role, responsibility and authority of the Risk Management Function,
- 2) Ensure the independence of the Risk Management Function according to best practices,
- 3) Define the Board's risk appetite and risk management program for all key risks, subject to annual review,
- 4) Monitor the risk strategy and policies recommended by management and ensure compliance with the risk tolerance,
- 5) To receive and review quarterly risk reports on:
 - Level of risk
 - Significant risk exposures in the Fund
 - Results of risk control initiatives
 - Significant decisions by management.
- 6) Ensure that strategic objectives and overall activities are commensurate to the Board risk tolerance levels,
- 7) Review and assess the integrity of the risk control systems and ensure that risk policies and strategies are effectively managed,
- 8) Introduce such measures as in the committee's opinion may serve to enhance the adequacy and efficiency of the risk management policies, procedures, practices and controls applied at the Fund.
- 9) Ensure the resources for Risk management function is adequate in terms of appropriate infrastructure, including software and human resources.

ANNEX 12.3 :
RISK MANAGEMENT CHAMPIONS- ROLES AND RESPONSIBILITIES

- 1) Assisting the Manager- Internal audit & Risk to create a risk awareness culture within NSSF through:
 - Disseminating risk materials issued by the Manager, Internal audit and Risk e.g. circulating memos and emails from the Manager- Internal audit and risk, other risk literature, memos from the MT, brochures, posters, etc;
 - Follow up on actions spelt out in memos by the MT and the Manager Internal Audit and Risk e.g. documenting status of implementation of recommendations by branch management and sending these to the manager internal audit and risk;
 - Holding and facilitating refresher risk workshops and trainings under the instruction of the Manager- Internal Audit & Risk.
- 2) Act as a focal point of contact on risk issues for the concerned branch/department.
- 3) To facilitate the risk assessment exercise through dissemination of questionnaires to participants, collection of questionnaires from interviewed participants and coordinating the safe, secure and confidential transfer to the Manager, internal audit and risk.
- 4) Timely escalation of risk issues from the departments/branches to the Manager, Internal Audit and Risk.
- 5) Facilitating at department/branch level, the updating of the Risk Register on an annual basis.
- 6) Coordinating at department/branch/Sub-Branche level risk responses proposed by the Risk Management Unit though follow up with departmental/branch management on the progress of risk response initiatives and reporting these to the Manager- Internal Audit and Risk;
- 7) Preparation of Quarterly reports on actions taken by process/risk owners at the departments/branches.

ANNEX 12.4

INFORMATION SECURITY RISK ASSESSMENT AND TREATMENT PROCESS

- i. The Risk Owner shall identify all the available processes within the department/branch/sub branch and all the information within those processes should be subsequently highlighted.
- ii. Identify the information security risks (threats), classifying them as risks associated with loss of confidentiality, integrity and availability of information and determine their causes (vulnerabilities).
- iii. Analyze the information security risks using the likelihood and impact and determine the risk level as guided by the Risk Assessment Matrix Annex 12.1 in the ERM Framework.
- iv. The Analysis is done factoring in the existing controls in place.
- v. Evaluate the information security risks level results as guided by the Risk Acceptance criteria (Ref Table 3) and prioritize the risk.
- vi. Select appropriate treatment options (Ref Table 4) taking into account the risk assessment results.
- vii. Determine all additional controls that can address the information security risk treatment option(s) chosen.
- viii. Compare the controls determined in (vii) above with those in Annex A and verify that no necessary controls have been omitted.
- ix. The Fund shall produce and communicate a Statement of applicability that contains the necessary controls in 7 & 8 justifying whether they are implemented or not and the justification for exclusions of controls from **Annex A**.
- x. Where the control determined in (vii) above is not in the Annex the said control to be referred to the risk officer for inclusion in the Statement of applicability (SOA) of the Fund.
- xi. Formulate a risk treatment plan indicating the actions to take in implementing controls, the resources required the time frame with the risk owner's approval.